Palacan

POLICY

Security Policy

How to report a vulnerability, what is in scope, the rules for testing and our response times.

This document is generated from the public repository, where the most recent version is always available: github.com/Sbirringa/palacan-client

Version of 9 November 2026, from commit `d1261f8`

Source: `SECURITY.md`

© 2026 Palacan. All rights reserved.

Security policy

Palacan is an end-to-end encrypted messenger. This repository contains the code that runs on your device: the web app, the cryptography module and the formal models. Security reports about this code, the website and the apps are very welcome.

Reporting a vulnerability

Please report privately, using **"Report a vulnerability"** in the **Security** tab of this repository (GitHub private vulnerability reporting). Do not open a public issue for a security problem.

A good report includes:

- what is affected (file, function, page or protocol step) and which commit or release you looked at;
- the impact you expect (for example: reading messages, impersonating a user, bypassing a check);
- the steps to reproduce it, or a proof of concept;
- whether you think it is already being exploited.

You can write in English or Italian.

What happens next

- We aim to acknowledge your report within **7 days**.
- We aim to give you a first assessment (accepted, needs more information, or not a vulnerability) within **30 days**.
- We fix accepted issues as fast as their severity requires, and we tell you when the fix is deployed.
- With your permission, we credit you when the fix is published. If you prefer to stay anonymous, we respect that.

Please give us reasonable time to fix the problem before you disclose it publicly. We will agree a disclosure date with you; by default we ask for up to **90 days** from your report.

Scope

In scope:

- the code in this repository: the web app (`frontend/my-react-app/vite-project/src`), the cryptography module (`crypto/palacan-crypto`), the release signature and the reproducible build (`frontend/my-react-app/vite-project/sicurezza`, `frontend/my-react-app/vite-project/scripts`), the **Palacan Verifica** browser extension (`frontend/my-react-app/vite-project/estensione`);
- the protocol described in `docs/PROTOCOL.md`;
- the public website, when the problem lets someone read or alter messages, keys or other users' data, or run code in the page.

Out of scope:

- denial of service, volumetric attacks and rate-limit tests against the production servers;
- social engineering, phishing and physical attacks;
- problems that need a device that is already fully compromised (malware with access to the unlocked browser);
- the limits already described in `docs/ARCHITECTURE.md` and in `formale/README.md`, unless you show they are worse than described.

Rules for testing

- Test only with accounts you created yourself. Never access, modify or delete other people's data.
- Do not run automated scans or load tests against production.
- If you accidentally access someone else's data, stop, do not keep a copy, and tell us in your report.

Research done in good faith and following these rules is welcome, and we will not take legal action against it. The license of this repository (`LICENSE`) explicitly allows security research on this code.

Supported versions

Only the version currently published on the website is supported. You can check which commit that is with the **Palacan Verifica** extension or with the steps in `docs/VERIFICATION.md`.